ESEN

C I B E R S E G U R I D A D

Proyecto Final · Entregable E.05

Matriz de riesgos: escalas, mapa de calor y tratamientos

Ejemplo resuelto de cátedra · Nexo Crítico Consultores · Energía Nacional S.A. de C.V. (ENSA)

Formato oficial del entregable E.05 de la Guía del Estudiante del Proyecto Final (2026), llenado íntegramente

Docente: Ing. Héctor Cuchilla

ESEN – CIBERSEGURIDAD – CICLO 03 – 2026

Tabla de contenidos

1. Identificación del equipo..... 3
2. Instrucciones de uso..... 3
3. Matriz de riesgos: escalas, mapa de calor y tratamientos..... 3
D.1 Escala de probabilidad (1–5)..... 3
D.2 Escala de impacto (1–5)..... 4
D.3 Mapa de calor 5×5 y niveles de riesgo..... 4
D.4 Tratamientos y riesgo residual..... 4
D.4-bis Apetito de riesgo declarado por la dirección simulada..... 4
D.5 Plantilla del registro de riesgos..... 5
D.5-bis Mapa de calor de la organización (ID de cada riesgo en su celda)..... 7
D.6 Cuantificación de los riesgos Críticos: continuación del BIA (frontera del Paso 9 de la Guía BIA)..... 7
D.7 Sensibilidad del ARO (Paso 12 de la Guía BIA aplicado a la frecuencia)..... 9
Supuestos declarados en este entregable..... 9
Trazabilidad hacia el diseño de controles..... 9

1. Identificación del equipo

Campo	Registro
Equipo	Nexo Crítico Consultores
Organización del catálogo	Energía Nacional S.A. de C.V. (ENSA) — perfil n.° 4
Grupo de Implementación asignado	IG3
Integrantes	Seis, con los cinco roles cubiertos
Fecha de entrega	viernes 23 de octubre de 2026 (H3)
Versión del documento	v1.0

2. Instrucciones de uso

- La plantilla se completa para la organización asignada al equipo en el Catálogo de Empresas 2026.
- La sección E.05 de la Guía del Estudiante del Proyecto Final describe el objetivo de este entregable, sus insumos, los pasos, el llenado campo por campo, un ejemplo resuelto, los errores frecuentes, el checklist de cierre y la fecha de entrega.
- Este archivo es el ejemplo resuelto con ENSA: conserva el formato, los encabezados y el pie de la plantilla en blanco, y muestra el nivel de detalle que el proyecto espera. El equipo trabaja sobre su propia plantilla y con su propia organización.
- Nombre del archivo de entrega en Moodle: E05_Matriz_Riesgos_<Equipo>.docx (o .pdf).

3. Matriz de riesgos: escalas, mapa de calor y tratamientos

Fundamento: NIST SP 800-30 r1 (guía de evaluación de riesgos). El riesgo se identifica como la combinación de una amenaza que explota una vulnerabilidad sobre un activo, y se valora como **probabilidad × impacto** con las escalas 1 –5 siguientes. La matriz registra el riesgo **inherente** (antes de controles), el **tratamiento** elegido y el riesgo **residual** (después del tratamiento), y la dirección declara su **apetito de riesgo**: el nivel con el que acepta convivir. Los puntos únicos de falla de E.03 (B.4) entran como vulnerabilidades y el costo por hora del BIA sustenta la valoración del impacto.

Ejemplo resuelto de cátedra · entrega: viernes 23 de octubre de 2026 (H3).

D.1 Escala de probabilidad (1–5)

Nivel	Nombre	Criterio
5	Casi seguro	Se espera que ocurra en el año; hay antecedentes en la organización o en el sector con alta frecuencia.
4	Probable	Es factible que ocurra en el año; el sector reporta casos frecuentes (p. ej. phishing, ransomware).
3	Posible	Puede ocurrir en un horizonte de 1 a 3 años; existen condiciones que lo facilitan.
2	Improbable	Ocurrencia rara; exige condiciones poco frecuentes o un atacante con capacidades altas.
1	Excepcional	Ocurrencia muy rara; sin antecedentes relevantes en el sector.

D.2 Escala de impacto (1–5)

Nivel	Nombre	Criterio (financiero · operativo · legal y regulatorio · reputacional · seguridad de las personas)
5	Catastrófico	Compromete la continuidad de la organización o la seguridad de las personas: pérdida financiera mayor, interrupción de un proceso crítico más allá de su MTPD con daño a terceros, daño reputacional severo o sanción regulatoria grave (p. ej. incumplir la notificación de 72 h de la LPDP en una brecha masiva de datos personales).
4	Mayor	Interrupción de un proceso crítico más allá de su MTPD, pérdida financiera importante o sanción regulatoria significativa.
3	Moderado	Interrupción dentro de los tiempos tolerables, pérdida financiera media o afectación reputacional local.
2	Menor	Degradación del servicio sin interrupción de procesos críticos; costo de respuesta bajo.
1	Insignificante	Afectación mínima absorbida por la operación normal.

D.3 Mapa de calor 5×5 y niveles de riesgo

El producto probabilidad × impacto (1–25) se clasifica en cuatro niveles, que colorean el mapa de calor del informe: **Crítico** (17–25), **Alto** (10–16), **Medio** (5–9) y **Bajo** (1–4). Regla de decisión del proyecto: todo riesgo Crítico o Alto recibe tratamiento con controles (y es candidato natural a los seis controles a profundidad de E.07); los Medios se tratan o se aceptan con justificación; los Bajos se aceptan y se monitorean.

P \ I	1	2	3	4	5
5	5 · Medio	10 · Alto	15 · Alto	20 · Crítico	25 · Crítico
4	4 · Bajo	8 · Medio	12 · Alto	16 · Alto	20 · Crítico
3	3 · Bajo	6 · Medio	9 · Medio	12 · Alto	15 · Alto
2	2 · Bajo	4 · Bajo	6 · Medio	8 · Medio	10 · Alto
1	1 · Bajo	2 · Bajo	3 · Bajo	4 · Bajo	5 · Medio

D.4 Tratamientos y riesgo residual

- **Mitigar:** reducir probabilidad o impacto con controles; es el tratamiento que conecta con los controles CIS del proyecto.
- **Transferir:** trasladar parte del impacto mediante seguros o contratos con terceros.
- **Evitar:** eliminar la actividad que genera el riesgo.
- **Aceptar:** asumirlo formalmente cuando su nivel cae dentro del apetito declarado; la aceptación la firma la dirección simulada.

D.4-bis Apetito de riesgo declarado por la dirección simulada

Campo	Registro
Apetito de riesgo (nivel residual máximo aceptable y condiciones)	Ningún riesgo Crítico o Alto queda sin tratamiento. El residual máximo aceptable es Medio para los procesos críticos y Bajo para los procesos que afectan la seguridad de las personas cuando el control esté operando en régimen. Los riesgos Medios se aceptan con justificación escrita y revisión trimestral; los Bajos se monitorean. Ningún riesgo sobre el entorno de tecnología de operación se acepta sin tratamiento, cualquiera que sea su nivel.

Campo	Registro
Aprobado por (nombre y cargo simulados)	Ing. Óscar Mauricio Handal, Gerente General, con el respaldo de la Jefatura de Seguridad de la Información
Fecha y firma	21 de octubre de 2026 · (firma)

D.5 Plantilla del registro de riesgos

ID	Activo	Amenaza	Vulnerabilidad	P	I	Justificación de P e I (una línea)	Inherente	Tratamiento	Control CIS asociado	Residual (P×I)
R-01	A-01, A-03, A-04	Ransomware que se propaga desde la red de TI al entorno de control (eje: tecnología de operación)	B-02: puntos de conexión TI–OT sin filtro documentado; el aislamiento declarado no es real	4	5	P: el sector eléctrico de la región reporta campañas con efecto en OT · I: supera el MTPD de 4 h y alcanza la seguridad de terceros	20 · Crítico	Mitigar	12 y 13	2×4 = 8 · Medio
R-02	A-01, A-07, A-17	Manipulación de comandos de control por uso indebido del acceso remoto del proveedor (eje: terceros y cadena de suministro)	SPOF-04 / B-05: acceso permanente con usuario compartido, sin multifactor ni registro	4	5	P: credencial compartida y expuesta a reutilización · I: maniobra no autorizada sobre la red energizada	20 · Crítico	Mitigar	6 y 15	2×4 = 8 · Medio
R-03	A-04, A-08	Intrusión persistente no detectada en la red OT (eje: tecnología de operación)	B-03 / B-04: sin inventario de activos OT ni monitoreo de seguridad en esa red	4	4	P: superficie desconocida y sin detección · I: compromete la integridad de la operación y retrasa la respuesta	16 · Alto	Mitigar	1 y 13	2×4 = 8 · Medio
R-04	A-08, A-09	Compromiso de la infraestructura de medición para fraude masivo o desconexión remota	SPOF-05: concentrador único por zona; configuración de fábrica sin endurecer	3	4	P: exposición acotada pero con precedentes en el sector · I: pérdida de ingresos y afectación al cliente	12 · Alto	Mitigar	4 y 16	2×3 = 6 · Medio
R-05	A-09, A-12, A-13	Exfiltración de datos personales de clientes desde el sistema comercial (eje: identidad y datos)	Accesos amplios al sistema comercial y sin cifrado en las extracciones de datos	4	4	P: el dato tiene valor de mercado y el acceso es amplio · I: notificación obligatoria en 72 h y sanción bajo la LPDP	16 · Alto	Mitigar	3 y 8	2×3 = 6 · Medio
R-06	A-03, A-10, A-11, A-21	Indisponibilidad prolongada por imposibilidad de restaurar desde el respaldo	SPOF-08 / B-01: respaldo semanal en cinta, sin copia aislada ni prueba de restauración	3	4	P: el respaldo nunca se ha probado · I: recuperación fuera del RTO de 2 h y del RPO de 15 min	12 · Alto	Mitigar	11	2×3 = 6 · Medio

ID	Activo	Amenaza	Vulnerabilidad	P	I	Justificación de P e I (una línea)	Inherente	Tratamiento	Control CIS asociado	Residual (P×I)
R-07	A-16, A-17, A-22	Compromiso de credenciales privilegiadas de administración de TI y de TO por phishing (eje: identidad)	SPOF-03: autenticación de operadores dependiente del directorio corporativo; sin multifactor ni gestión de acceso privilegiado	5	4	P: el phishing dirigido es el vector más frecuente y hay antecedentes de intentos · I: acceso administrativo a los dos procesos críticos y a los sistemas comercial y de medición	20 · Crítico	Mitigar	5, 6 y 14	2×4 = 8 · Medio
R-08	A-18, A-22, A-23	Suplantación del centro de control o del cliente con voz y correo generados con inteligencia artificial (eje: IA)	Verificación de identidad en llamadas y correos basada solo en datos conocidos por el interlocutor	4	3	P: las herramientas de generación están al alcance de cualquier atacante · I: maniobra indebida o fuga de datos acotada	12 · Alto	Mitigar	9 y 14	2×3 = 6 · Medio
R-09	A-07, A-15	Actualización maliciosa o mantenimiento comprometido de un proveedor tecnológico (eje: cadena de suministro)	Sin verificación de integridad de las actualizaciones ni cláusulas de seguridad exigibles en el contrato	3	5	P: los ataques a proveedores de sistemas de control tienen precedentes documentados · I: compromiso simultáneo de la plataforma de control	15 · Alto	Mitigar y transferir	15 y 16	2×4 = 8 · Medio
R-10	A-24	Imposibilidad de investigar un incidente por ausencia de evidencia	B-04: bitácoras dispersas en cada equipo, sin recolección central ni retención definida	4	3	P: la condición es permanente hoy · I: prolonga la respuesta y debilita la posición ante el regulador	12 · Alto	Mitigar	8	2×3 = 6 · Medio
R-11	A-05, A-19, A-20	Acceso físico no controlado a subestaciones, armarios de comunicación y repetidores	SPOF-07 y B-07: repetidor sin respaldo de energía y videovigilancia fuera del alcance con convergencia no resuelta	3	4	P: instalaciones distribuidas y sin supervisión permanente · I: degrada el medio alterno justo en la contingencia	12 · Alto	Mitigar	12 y controles físicos	2×3 = 6 · Medio
R-12	A-01, A-02, A-10, A-12	Explotación de vulnerabilidades conocidas en servidores, estaciones HMI y aplicaciones	B-06: sin ventana de mantenimiento ni proceso de parcheo en el entorno OT	4	4	P: exposición sostenida a vulnerabilidades publicadas · I: compromiso de plataformas de los dos procesos críticos y del sistema comercial	16 · Alto	Mitigar	7	2×3 = 6 · Medio
R-13	A-14, A-15	Explotación de vulnerabilidades del portal web de clientes	Desarrollo del portal contratado sin ciclo de vida seguro ni pruebas de seguridad previas a la publicación	3	3	P: aplicación expuesta a internet · I: afecta datos de clientes sin comprometer la operación de la red	9 · Medio	Mitigar	16	2×2 = 4 · Bajo

ID	Activo	Amenaza	Vulnerabilidad	P	I	Justificación de P e I (una línea)	Inherente	Tratamiento	Control CIS asociado	Residual (P×I)
R-14	A-06	Indisponibilidad de la única competencia de administración del sistema SCADA	SPOF-01 / B-08: configuración no documentada y competencia no replicada	3	4	P: una sola persona, con vacaciones y rotación posibles · I: recuperación fuera del RTO con dependencia del fabricante	12 · Alto	Mitigar y transferir	14 y 15	2×3 = 6 · Medio

Los catorce riesgos cubren los veinticuatro activos del inventario de E.04 y los doce puntos únicos de falla y brechas que la consolidación del BIA trasladó en su tabla B.4. Los ejes de amenaza activos del perfil aparecen de forma explícita: tecnología de operación (R-01, R-03, R-11), identidad (R-05, R-07), terceros y cadena de suministro (R-02, R-09, R-13) e inteligencia artificial (R-08). El eje de nube no está activo en este perfil: ENSA no declara servicios en nube y sus plataformas son locales, de modo que se registra como eje no aplicable y se reevalúa cuando se apruebe la migración del portal de clientes, que el roadmap de E.10 sitúa en el largo plazo.

D.5-bis Mapa de calor de la organización (ID de cada riesgo en su celda)

P \ I	1 Insignificante	2 Menor	3 Moderado	4 Mayor	5 Catastrófico
5 Casi seguro				R-07	
4 Probable			R-08, R-10	R-03, R-05, R-12	R-01, R-02
3 Posible			R-13	R-04, R-06, R-11, R-14	R-09
2 Improbable					
1 Excepcional					

Tres riesgos Críticos (R-01, R-02 y R-07), diez Altos y uno Medio. Después del tratamiento, ningún riesgo permanece por encima de Medio y el residual del portal de clientes baja a Bajo, dentro del apetito declarado por la dirección.

D.6 Cuantificación de los riesgos Críticos: continuación del BIA (frontera del Paso 9 de la Guía BIA)

El BIA (E.03, tabla B.2) entrega el SLE = AV × EF de cada proceso crítico y el SLE de exposición de datos de cada proceso importante con los datos personales que cuantifica la ficha. La matriz de riesgos añade lo que el BIA deja fuera por diseño: la frecuencia. Para cada riesgo Crítico se completa la justificación del control en los cinco pasos de la Guía BIA: (1) ALE actual = SLE × ARO sin control adicional; (2) efectividad del control, como reducción del ARO o del EF sustentada en especificaciones o estudios; (3) ALE con el control operando; (4) beneficio = ALE actual − ALE con control; (5) costo anual del control (ACC) en sus tres familias: adquisición anualizada, operación y mantenimiento. El retorno se expresa como ROSI = (Beneficio − ACC) ÷ ACC, y el control se justifica cuando el ACC es menor que la reducción de ALE que produce. Los supuestos (AV, EF, ARO) se varían en los escenarios mínimo, esperado y máximo de B.5.

Riesgo	Proceso · escenario (SLE-nn de E.03)	SLE (USD)	ARO actual	ALE actual	Efectividad	ARO con control	ALE con control	Beneficio	ACC (adq. + oper. + mant.)	ROSI
R-01	P-01 SCADA/OT · SLE-01	4 950 000	0,5	2 475 000	Segmentación con zona intermedia y detección pasiva: ARO 0,5 → 0,2	0,2	990 000	1 485 000	186 000 (96 000 + 62 000 + 28 000)	698 %
R-02	P-01 SCADA/OT · SLE-01	4 950 000	0,5	2 475 000	Multifactor, cuenta nominal por técnico y grabación de sesión: ARO 0,5 → 0,1	0,1	495 000	1 980 000	96 000 (48 000 + 34 000 + 14 000)	1 963 %
R-07	P-04 Sistema Comercial y Facturación (importante) · SLE-03	1 395 000	1,0	1 395 000	Multifactor en toda cuenta administrativa, gestión de acceso privilegiado y campaña de concientización: ARO 1,0 → 0,2	0,2	279 000	1 116 000	112 000 (52 000 + 44 000 + 16 000)	896 %
R-04	P-02 Medición Inteligente (AMI) (importante) · SLE-04	480 000	0,2	96 000	Endurecimiento de concentradores y verificación de firmware: ARO 0,2 → 0,05	0,05	24 000	72 000	78 000 (40 000 + 26 000 + 12 000)	−8 %

Convención de estimación del proyecto (se aplica salvo que el equipo cite una fuente mejor, que entonces se referencia con edición y año): el ARO se deriva del nivel de probabilidad de D.1 —5 ≈ 1 evento al año · 4 ≈ 0,5 · 3 ≈ 0,2 · 2 ≈ 0,1 · 1 ≈ 0,05—; la efectividad del control se expresa como la reducción de al menos un nivel de probabilidad (o del factor de exposición) justificada en una línea; el costo de adquisición se anualiza sobre una vida útil de cinco años. La tabla D.6 se completa para los riesgos Críticos y, cuando hay menos de tres Críticos, también para los Altos de nivel 15 o 16. Los ALE no se suman entre riesgos que comparten proceso: la exposición del proceso es el mayor de ellos. El ROSI decide si un control se justifica, y el orden de implantación se decide por beneficio absoluto y por dependencias.

Las tres primeras filas corresponden a los riesgos Críticos, como exige el método, y cada fila cita el SLE del escenario de E.03 que corresponde al riesgo —en R-07 y R-04, el que P-04 y P-02 conservan como procesos importantes—; R-05, exfiltración de datos de clientes, dispone del SLE-05 de exposición (USD 105 000). La cuarta se añade por decisión del equipo porque su resultado no es obvio: el control dedicado no se justifica por sí solo en el escenario esperado, y la recomendación que E.10 recoge es incorporar el endurecimiento de los concentradores al alcance del control 4 del baseline en lugar de abrir un proyecto propio.

R-01 y R-02 comparten proceso, de modo que sus pérdidas anuales esperadas no se suman: la exposición del proceso de control de red es la mayor de ambas, USD 2 475 000. El orden de implantación lo decide la dependencia técnica: la segmentación de R-01 habilita el resto del diseño de red, y por eso encabeza el corto plazo del roadmap aunque R-02 tenga mejor retorno.

D.7 Sensibilidad del ARO (Paso 12 de la Guía BIA aplicado a la frecuencia)

Riesgo	ARO mínimo	ARO esperado	ARO máximo	ALE actual (mín / esp / máx)	Beneficio (mín / esp / máx)	ACC	¿El control se justifica en los tres escenarios?
R-01	0,2	0,5	1,0	990 000 / 2 475 000 / 4 950 000	594 000 / 1 485 000 / 2 970 000	186 000	Sí en los tres; el mínimo aún rinde 219 %
R-02	0,2	0,5	1,0	990 000 / 2 475 000 / 4 950 000	792 000 / 1 980 000 / 3 960 000	96 000	Sí en los tres; es el control de mejor retorno del proyecto
R-07	0,5	1,0	2,0	697 500 / 1 395 000 / 2 790 000	558 000 / 1 116 000 / 2 232 000	112 000	Sí en los tres
R-04	0,1	0,2	0,4	48 000 / 96 000 / 192 000	36 000 / 72 000 / 144 000	78 000	No: solo se justifica en el escenario máximo; el informe lo dice con esas palabras y propone absorberlo en el control 4

Regla de calidad: la matriz contiene al menos doce riesgos que cubren los activos críticos de E.04; los ejes de amenaza activos del perfil (IA, identidad, nube, terceros y cadena de suministro, tecnología de operación: los que los sistemas, la red y la madurez actual del perfil activan) aparecen entre las amenazas, con nota de los que no aplican; y cada riesgo Crítico o Alto traza a un control de E.07 o a una salvaguarda del baseline de E.08.

La sensibilidad usa los rangos de frecuencia del registro de supuestos del BIA (BIA_P06, sección 6) y la convención de estimación del proyecto, que deriva el ARO del nivel de probabilidad: 5 ≈ 1 evento al año · 4 ≈ 0,5 · 3 ≈ 0,2 · 2 ≈ 0,1 · 1 ≈ 0,05. La efectividad de cada control se expresa como la reducción de al menos un nivel de probabilidad, justificada en una línea, y el costo de adquisición se anualiza sobre cinco años de vida útil.

Supuestos declarados en este entregable

Solo se declara como supuesto lo que ni el perfil del catálogo ni la ficha de datos del cliente traen: un dato que la ficha trae nunca se sustituye por un supuesto. Cada supuesto lleva un identificador global y correlativo en todo el proyecto (S-01, S-02…): el entregable continúa la numeración del anterior y E.11 los consolida en su Anexo A. Cuando el entregable no declara supuestos, la primera fila lo dice.

ID (S-nn, numeración global)	Supuesto	Fundamento u origen
—	Sin supuestos nuevos en este entregable.	Las escalas, el apetito de riesgo y la convención del ARO son reglas del proyecto; los SLE salen de la tabla B.2 de E.03.

Trazabilidad hacia el diseño de controles

Riesgo	Nivel inherente	Va a E.07 (control desarrollado a profundidad)	O queda cubierto por el baseline de E.08
R-01	Crítico	Controles 12 y 13	—
R-02	Crítico	Controles 6 y 15	—
R-07	Crítico	Control 6, con apoyo del 14 en el baseline	Salvaguardas del control 5 y del 14
R-03	Alto	Control 13	Salvaguardas del control 1

Riesgo	Nivel inherente	Va a E.07 (control desarrollado a profundidad)	O queda cubierto por el baseline de E.08
R-05	Alto	—	Salvaguardas de los controles 3 y 8
R-06	Alto	Control 11	—
R-12	Alto	Control 7	—
R-09	Alto	Control 15	Salvaguardas del control 16
R-04	Alto	—	Salvaguardas de los controles 4 y 16
R-08	Alto	—	Salvaguardas de los controles 9 y 14
R-10	Alto	Control 13, por la recolección que alimenta la detección	Salvaguardas del control 8
R-11	Alto	Control 12, en lo que toca a la red de comunicación	Salvaguardas del control 12 y medidas físicas del programa
R-14	Alto	Control 15, por el contrato de respuesta del fabricante	Salvaguardas del control 14
R-13	Medio	—	Salvaguardas del control 16, cubiertas por tercero

Los seis controles desarrollados a profundidad en E.07 —12, 13, 6, 7, 11 y 15— son los que tratan los tres riesgos Críticos y siete de los diez Altos. Ningún riesgo Crítico o Alto queda sin control desarrollado ni sin salvaguarda del baseline que lo cubra.